

绿盟高级威胁狩猎系统产品白皮书

■ 文档编号	NSF-TR-RPM-081	■ 密级	完全公开
■ 版本编号	V1.0	■ 日期	2023/6/20



© 2023 绿盟科技

■ 版权声明

本文中出现的任何文字叙述、文档格式、插图、照片、方法、过程等内容，除另有特别注明，版权均属绿盟科技所有，受到有关产权及版权法保护。任何个人、机构未经绿盟科技的书面授权许可，不得以任何方式复制或引用本文的任何片断。

■ 版本变更记录			
时间	版本	说明	修改人
2023.6.20	V1.1.0	产品白皮书修订	薛诗莹

■ 适用性声明
本模板用于撰写绿盟科技内外各种正式文件，包括技术手册、标书、白皮书、会议通知、公司制度等文档使用。

目录

一. 客户面临的挑战.....	1
1.1 挑战1：合规政策.....	1
1.2 挑战2：安全事件.....	1
1.3 挑战3：技术趋势.....	1
1.4 挑战4：客户应用场景和痛点.....	2
1.4.1 场景一：攻防对抗场景.....	2
1.4.2 场景二：威胁溯源场景.....	2
1.4.3 场景三：日常防御场景.....	2
1.4.4 场景四：安全检查场景.....	3
1.4.5 场景五：威胁情报场景.....	3
二. 绿盟科技高级威胁狩猎解决方案.....	3
三. 产品功能与优势.....	4
3.1 产品概述.....	4
3.2 产品架构.....	4
3.2.2 狩猎大屏展示模块.....	5
3.2.3 感知节点管理模块.....	6
3.2.4 狩猎溯源情报模块.....	7
3.2.5 第三方联动模块.....	7
3.2.6 功能管理模块.....	7
3.3 产品功能.....	8
3.3.1 1:1业务仿真.....	8
3.3.2 攻击者狩猎溯源.....	8
3.3.3 双向威胁情报.....	9
3.3.4 提高攻击成本，实现攻击隔离.....	9
3.3.5 引流防御，有效消耗攻击资源.....	9
3.3.6 设置诱饵主动欺骗.....	10
3.3.7 入侵攻击链取证技术.....	10
3.3.8 高分辨率攻击者画像.....	11
3.3.9 不同烈度的定向攻击反制.....	11
3.3.10 第三方安全联动.....	12
3.4 产品技术.....	12
3.5 典型部署.....	12
3.6 产品优势.....	13
3.6.1 技术优势.....	13
3.6.2 体系优势.....	13

3.7 产品型号规格.....	14
四. 客户价值.....	15
4.1 化被动为主动，实现高级威胁防御.....	15
4.2 提高攻击成本，拖延攻击者时间.....	15
4.3 精准威胁溯源与攻击取证.....	15
4.4 企业安全产品联动.....	15
4.5 满足监管与合规需求.....	16
五. 成功案例.....	16
5.1 成功案例列表.....	16
5.2 典型成功案例.....	17
5.2.1 中国人民银行业务网网络安全纵深防御全流量安全监测分析与蜜罐建设项目	17
六. 总结.....	18

表格索引

表 3.1 虚拟化产品型号规格.....	14
表 3.2 硬件产品型号规格	14

插图索引

图 3.1 绿盟高级威胁狩猎系统（ATH）产品定位图	4
图 3.2 绿盟高级威胁狩猎系统（ATH）产品架构图	5
图 3.3 威胁狩猎监控态势大屏	6
图 3.4 诱饵欺骗原理示意图	10
图 3.5 入侵攻击链取证原理示意图	11
图 3.6 攻击者画像溯源维度示意图	11
图 3.7 典型部署示意图	13

一. 客户面临的挑战

挑战1：合规政策

《信息安全技术-网络安全等级保护基本要求》于2019年12月1日正式实施，简称“等保2.0”，其中明确指出企业应由被动防御体系转变为构建积极主动防御体系，强调具有主动防护与反制能力。制度实现对传统信息系统、基础信息网络、云计算、大数据、物联网、移动互联网和工控信息系统等级保护对象的全覆盖。

挑战2：安全事件

国内外大规模安全事件愈演愈烈，类似WannaCry、Struts2等安全事件在行业内的万千服务，直接或间接造成了巨额的经济损失。随着不断更迭的攻击手法，攻击方和防御方始终处于不对等的状态。从开始的简单攻击工具到后续的自动化工具到现在的武器库，攻击者的攻击行为也从单兵作战发展至团体行动，越来越多的APT组织被发现与公布。为了应对错综复杂的网络安全环境，应对不断发展的攻击手法。防御者也应转变视角，从单纯的被动防守转变为主动反击。

挑战3：技术趋势

如今的防御措施必将面临升级，从被动防御转向主动防御，甚至于欺骗反制。威胁狩猎是一种主动识别攻击痕迹的方法。有别于SOC（安全运营中心）、IDS（入侵检测系统）、渗透测试和扫描，由威胁狩猎分析师利用威胁分析平台、威胁情报和大量实践经验来积极筛选、分析网络和端点数据，寻找可疑的异常的或正在进行的攻击痕迹，去证明威胁假设，并寻找到背后的攻击者。

挑战4：客户应用场景和痛点

场景一：攻防对抗场景

攻防实战演练是由监管机构组织专业网络安全团队，针对参演单位提供的互联网资产，采用获取权限类、突破网络边界类、获取目标系统权限类、发现历史已有攻击事件类等攻击方式进行受控攻击。红蓝军对抗则是一方扮演黑客（蓝军），一方扮演防御者（红军），针对企业重要核心业务，模拟多种生动逼真的红蓝对抗（网络攻防）场景，揭示企业信息系统的漏洞与安全脆弱性，使企业人员了解常见网络攻击过程与实际防护，促进企业信息系统和信息安全管理制度的不断完善，从而更好地保护企业的数据信息安全。

根据攻防实战演练中的评分规则，防护者一方面要拖延攻击动作，加快处置工作，避免核心区域受损而造成大量失分；另一方面需要发现攻击行为，进行追踪溯源，回溯历史攻击事件，争取加分。部署蜜罐产品，一方面借助蜜罐仿真诱捕能力，增加网络复杂度，延缓攻击进程，降低核心区域失分的风险；另一方面通过对蜜罐、蜜饵的监控，更有效的发现攻击者的供给情况，并对攻击者身份进行溯源，提升得分概率。

场景二：威胁溯源场景

传统网络架构下的网络，普遍缺乏有效的网络安全防御产品。内部的生产网、办公网、测试网等网络环境中的系统和数据复杂多样，应用服务和数据又容易遭受网络攻击。针对APT等攻击行为的高隐蔽性、高危害性的特点，成为网络安全防御中薄弱的环节，一旦发生网络攻击事件，会带来非常严重的后果。

通过部署蜜罐实现实时感知入侵行为，利用攻击欺骗将攻击者引入蜜罐内虚假环境，一旦进入难以逃出，降低真实业务被攻击的风险损失，实现攻击者行为的入侵检测与威胁溯源系统，有效发现APT攻击行为，保护客户网络免遭未知威胁攻击造成的各种风险。

场景三：日常防御场景

传统“重外网、轻内网”的防守方式，难以发现攻击者在内网中的破坏行为，尤其是攻击者伪造进行和流量的手段，使其常常成为威胁检测的漏网之鱼。

针对攻击者的内网渗透行为，蜜罐产品具备快速精准的威胁感知能力能够有效弥补传统防御方式的不足，通过部署支持覆盖多网段、多IP的探针，可实现内网的大范围覆盖，协助防守方迅速发现攻击行为。另外丰富类型的蜜罐，可以有效欺骗攻击者，吸引攻击火力，从而避免攻击者对企业真实资产造成伤害。

场景四：安全检查场景

将蜜罐放到现有防护产品后面，核心数据资产周围，作为最后一道防线，并可以检验现有防护是否牢固。并将攻击流重定向引入至部署蜜罐系统中，实现攻击活动与客户网络环境的安全隔离，确保客户网络环境安全性。

场景五：威胁情报场景

传统网络架构下，部署在外网环境中的业务系统，因面向公网开放的特点，容易成为攻击目标，使其面临极大的安全风险，容易造成数据泄露、服务中断、系统异常等后果。针对网络监管机构、网络安全性要求高的行业，通过部署蜜罐能够更早的感知到潜在攻击者的探测行为，对捕获的各类攻击行为和攻击事件的数据进行关联分析和研究，输出威胁情报，能够及时掌握当前互联网网络攻击态势，对后续网络安全防护工作的规划提供重要依据。

二. 绿盟科技高级威胁狩猎解决方案

在国家级/省市级监管机构、金融行业和运营商行业等客户中，应对攻防演练、重保等重大活动期间的安全保障任务，以及企业内网安全防护场景下，提供更为复杂的高级威胁狩猎能力。基于演习保障期间建立的运转流程和安全机制转化为常态化、实战化、体系化的安全运营能力，提供应对企业内网安全监测的解决方案。蜜罐产品可以实现转守为攻，但是传统蜜罐的缺点明显：几乎不可能实现高真实、低成本、高覆盖的蜜罐服务。绿盟高级威胁狩猎系统（ATH）实现精准诱捕攻击行为，提供入侵活动线索，并进一步结合溯源反制与威胁情报，助力客户刻画攻击者画像，协助客户保护资产，是一款针对攻防对抗的实战化产品，目前提供标准硬件、国产化硬件以及标准虚拟化版本，以多样化的形态满足客户不同的需求。

三. 产品功能与优势

产品概述

绿盟高级威胁狩猎系统（NSFOCUS Advanced Threat Hunting System，以下简称“ATH”）采用欺骗防御技术（下一代蜜罐技术），精准诱捕攻击行为，提供入侵活动线索，并进一步结合溯源反制与威胁情报，助力客户刻画攻击者画像，协助客户保护资产，是一款针对攻防对抗的实战化产品。在国家“HW”活动中，多次斩获攻击者信息，协助客户成功溯源。

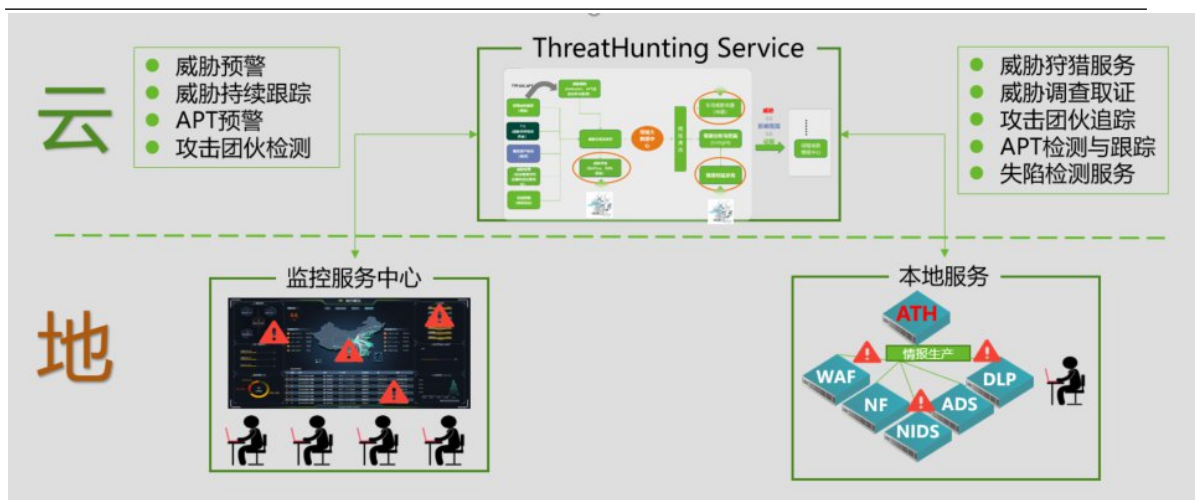


图 3.1 绿盟高级威胁狩猎系统（ATH）产品定位图

产品架构

绿盟高级威胁狩猎系统ATH（NSFOCUS Advanced Threat Hunting System）作为一款主动攻击反制类产品，在防守过程中能不仅能够对攻击行为进行欺骗和延缓攻击，并且可以诱骗攻击者并获取攻击者信息进行完整的画像，进而达到攻击反制的目的。实现企/事业单位办公网到生产网的全面覆盖，能够快速的部署在几乎所有的网络环境中，满足企业不同的管理模式需求，产品架构示意如下图所示：



图 3.2 绿盟高级威胁狩猎系统（ATH）产品架构图

狩猎大屏展示模块

狩猎大屏展示模块包含威胁发现、威胁事件、攻击源和狩猎事件分布等模块。实时显示目前用户环境的威胁情况。主要显示当前状态：动态显示当前狩猎场景图和受攻击实时动态展示，以及展示目前用户环境所面临的威胁情况。

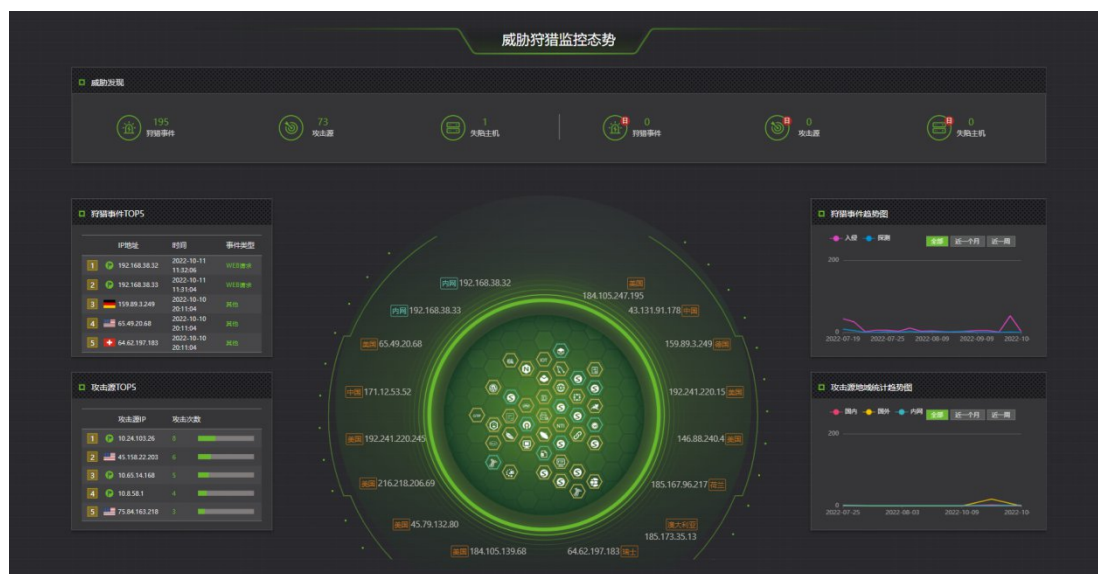


图 3.3 威胁狩猎监控态势大屏

威胁狩猎监控态势大屏中显示系统中狩猎事件数、攻击源数、失陷主机数、今日狩猎数、今日攻击源数和今日失陷主机数等，用户可清楚了解内网中被攻击资产数量总体和每天的数量分别是多少，以及发现的攻击源目前的数量是多少。

狩猎事件分布将对不同的狩猎场景的事件数量进行统计，用户可清楚了解目前系统中哪些狩猎场景遭受攻击，可了解每天在哪些类型资产遭受攻击次数最多以及可以获得的溯源情报。

感知节点管理模块

感知节点管理模块包含节点管理、探针管理、仿真服务管理、诱饵管理和第三方节点管理等模块。

节点管理模块通过在核心系统上部署的节点来诱捕攻击者，包含各节点列表的展示，能详细展示节点的类型、IP地址及监控状态，可对于节点进行管理，支持添加节点及配置节点漏洞，支持各类应用服务、系统服务、Windows、业务服务等等类型节点的创建、启停监听和删除等操作。

探针管理主要覆盖的场景是客户三层跨路由部署专用，将探针部署在业务机器上，将攻击者的攻击诱导到节点。支持探针IP、vlan及网关各类参数的配置功能。

仿真服务管理模块主要包括仿真模板、仿真服务和漏洞管理等模块。仿真模板是指节点创建需要的仿真服务模板，可创建新的仿真服务模板，也可直接使用内置的仿真服务模板。仿真服务是指目前系统支持的仿真服务的列表，也支持自定义仿真服务。漏洞管理是指目前系统支持的漏洞列表，也支持自定义添加漏洞管理。

诱饵设置是通过诱饵将攻击者引诱至节点，诱饵设置模块包含内网诱饵和互联网诱饵的诱饵设置。内网诱饵可自定义添加包含历史命令和主机名等等维度的诱饵信息，并下载诱饵脚本。互联网诱饵可自定义添加主机名、用户名、密码、邮箱和端口等等，支持用户在互联网上散布欺骗防御信息，迷惑攻击者。

狩猎溯源情报模块

狩猎溯源模块主要从狩猎事件、攻击源和失陷主机维度进行溯源分析，可通过狩猎场景、狩猎视角、源IP、自定义攻击时间、事件类型等等维度进行方式查询方式。

狩猎场景主要包括数据库狩猎、Web狩猎、IOT狩猎、邮件狩猎、基础服务狩猎、文件共享狩猎、远程登录狩猎等。

狩猎事件类型分为暴力破解、命令执行、代理转发、扫描探测、数据库操作、横向移动、恶意邮件、DDoS攻击、外连URL、文件泄露、恶意文件加载、尝试登陆和其他。

支持攻击者画像分析，能详细查看攻击者身份、标备注、攻击者轨迹等信息。支持设备指纹的溯源，包含操作系统、显卡设备等详细信息。支持查看攻击者轨迹，记录详细时间段的攻击事件详情，包含攻击时间、攻击资产、攻击方式及操作，并支持攻击事件、攻击源的展示，对攻击者IP、端口和服务指纹、探测时间进行记录。支持对攻击者溯源信息生成报告。

第三方联动模块

第三方联动模块支持日志同步和情报联动。日志同步支持将攻击事件发送到指定Syslog服务器，情报联动支持将攻击者IP发送到指定设备，如本地安全管理平台等，有效对恶意IP进行封堵。

功能管理模块

功能管理模块主要包括威胁狩猎、威胁感知、运营报告、狩猎日志、功能配置和系统管理等。

威胁狩猎主要是根据不同的狩猎场景进行被威胁呈现和展示，其中可以根据不同的狩猎场景、狩猎视角、时间、事件类型等进行不同的查询和展示。

威胁感知是指对感知集群、感知节点、探针、仿真服务、诱饵等等进行配置和操作。

运营报告是指根据不同时间粒度，时间范围、关注重点的报告。

狩猎日志是指原始日志和原始告警数据进行展示和进一步分析。

功能配置主要包括Syslog配置、日志配置、NTP配置、邮箱配置等等配置功能。

系统管理主要包括情报导入、系统监控、诊断工具、升级管理和用户管理等功能。

产品功能

1:1业务仿真

ATH在客户不同业务网络架构中部署不同的仿真服务节点，组成整套的威胁狩猎欺骗防御网络，仿真各种包括数据库、Web、基础服务等等，不同类型的真实环境并全方位对攻击者进行欺骗，混淆攻击者的攻击目标，保护真实的业务系统，实现纵深的业务仿真，防止客户真实资产被攻击。

通过在仿真业务系统中，动态配置无法被攻击者获取权限的系统漏洞，吸引攻击者注意力，提高欺骗资产对攻击者的诱捕能力。内置适配多种场景下的感知节点模板，用户也可随意组合不同高交互感知节点服务组合形成新的感知节点模板。在攻防对抗中根据实际情况调整诱捕策略。内置仿真模板包括但不限于服务器区仿真模板、DMZ区仿真模板、数据库仿真模板、核心业务仿真模板、常规业务仿真模板、办公区仿真模板和端口服务模板等等。

攻击者狩猎溯源

ATH的威胁狩猎模块可以详细记录攻击者执行的操作，并且可以获取攻击者的浏览器信息、操作系统信息、地理地址、设备的指纹等信息，方便客户针对此攻击者的取证调查和溯源追踪，自适应溯源攻击者的“黑客社交画像”信息，包括社交账号、用户ID等信息，支持多种黑客社交画像，并支持动态展示，此外该模块可对攻击者的行为进行分析，可了解到攻击者的攻击时间，攻击手法等。

针对攻击事件进行精准威胁溯源，可对发起攻击行为的内部源头进行查找。依托ATH感知节点、诱饵、狩猎蜜网的高交互性，诱导攻击者深度入侵系统，对整个攻击事件进行复现，清晰掌握攻击轨迹和行为细节，结合设备指纹和攻击者画像等技术可以实现攻击溯源，同时清楚掌握内部存在的安全漏洞及风险，保护客户网络免遭高级威胁攻击造成的各种风险，如敏感信息泄露、基础设施破坏等。

双向威胁情报

OSINT威胁情报是发现高级威胁的必要手段，绿盟科技威胁情报已入选Gartner《全球威胁情报指南》，获得业界强烈认可。ATH基于绿盟威胁情报中心，为客户提供最全的威胁情报数据，自动检索和关联分析，提前洞察各类安全威胁，形成协同的安全监控响应一体防御方案，为企业提供真实可靠的攻击者威胁情报。

ATH对客户内网中发现的攻击者行为进行分析，可了解到攻击者的攻击时间，攻击手法等，并获取攻击者的浏览器信息、操作系统信息、地理地址、设备指纹等信息，实现客户内网中自有的内部威胁情报，并根据攻击者的恶意行为，对捕获的各类攻击行为和攻击事件的数据进行关联分析和研究，能够及时掌握当前互联网网络攻击态势，实现欺骗防御自身响应。

提高攻击成本，实现攻击隔离

感知节点是在客户网络中部署的高度模仿客户资产信息的系统，根据客户不同的需求可以仿真出客户不同的系统和不同的业务，如应用服务感知节点，系统服务感知节点等，用户还可根据自己的需求自行定义感知节点，从而满足用户的特殊需求。将攻击者的流量隔离进ATH的感知节点，既能检测攻击者的行为，让攻击者不触碰到真实资产，又能拖延攻击者攻击时间，提供攻击成本，主动暴露攻击者身份、攻击手法、攻击目的等，从而实现攻击隔离。一旦发现真实攻击，立即切断，防止攻击者攻击真实业务。

引流防御，有效消耗攻击资源

传统的威胁处置是采取封堵IP的操作，但攻击者大概率会换IP再次发起攻击，防守方只能疲于应对。ATH支持引流防御，可将访问真实业务的攻击流量引流到仿真感知节点，对于攻击者来说，攻击的目标是真实业务，实际在内部已被替换成仿真业务感知节点，攻击者无法命中真实目标。相对真实封堵IP，引流防御不仅直接保护了真实资产，而且有效消耗攻击

资源。通过引流防御，可主动捕获攻击流量，攻击者命中感知节点的概率达到100%，解决了感知节点被动诱捕的弊端，并可主动对攻击者溯源、攻击反制，化被动为主动。

设置诱饵主动欺骗

诱饵层面ATH支持内网诱饵和互联网诱饵的构建，内网诱饵可自定义添加包含历史命令和主机名等等维度的诱饵信息，并下载诱饵脚本。互联网诱饵可自定义添加主机名、用户名、密码、邮箱和端口等等，支持用户在互联网上散布欺骗防御信息，迷惑攻击者，将潜伏的攻击者引诱到欺骗防御资产中，将潜伏在企业内网的威胁感知引诱出来，缩短企业内网威胁的暴露时间。

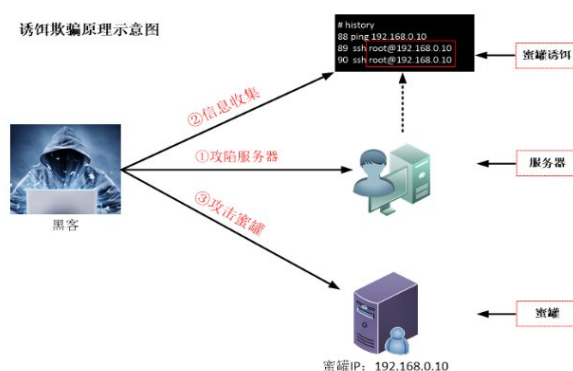


图 3.4 诱饵欺骗原理示意图

入侵攻击链取证技术

ATH产品结合网络攻击行为分析和感知节点行为分析，极大地提高了攻击链条的取证准确率，将攻击分为：探测扫描、渗透攻击、攻陷感知节点、后门远控、跳板攻击五大阶段。

用户可以一键提取攻击链条日志，形成取证证据。



图 3.5 入侵攻击链取证原理示意图

高分辨率攻击者画像

ATH支持记录并分析出攻击者画像。ATH攻击者画像支持3个维度，包括：设备指纹、位置信息和社交指纹，3个维度具体的溯源信息如下图所示。

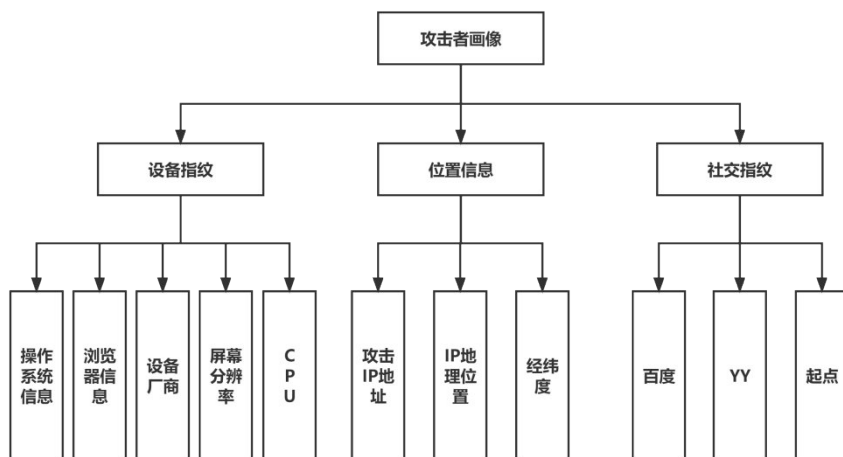


图 3.6 攻击者画像溯源维度示意图

不同烈度的定向攻击反制

攻击者访问仿真业务感知节点时，支持主动对指定攻击者发起攻击反制行为，包括：木马诱骗反制、漏洞攻击反制等，具体如下：

1. 木马诱骗反制：生成诱饵文件蜜罐攻击者，实现信息引流，引诱攻击者根据诱饵文件主动上钩访问蜜罐，从而实现灵活指定对某个攻击源IP地址发起木马诱骗反制。

2. 漏洞攻击反制：支持一键扫描攻击源IP地址，探测攻击者主机的开放端口信息、弱口令、漏洞等，获取攻击者信息。

第三方安全联动

ATH对攻击者每个行为都可以进行记录,会详细记录攻击者执行的操作。可通过告警系统进行实时报警,对每个攻击行为都可通过联动系统与SYSLOG日志服务器或其他服务器进行无缝联动，方便管理分析。也可与IPS、WAF等安全阻断设备联动，实现安全联动，快速阻断，缩短攻击者攻击时间，建立起一套有效保护业务系统安全性的纵深防御体系。

产品技术

绿盟高级威胁狩猎（ATH）作为一款全新的产品，结合蜜罐技术对攻击者进行欺骗和捕获。将防守方变被动为主动，不仅能够延缓攻击者的攻击进程也能够对攻击者进行溯源和捕获。ATH在捕获攻击者的过程中产生有效的日志，是作为内生安全的重要组成部分，不仅能够对攻击者进行精确的画像而且还可以对攻击者进行事件溯源和反制。

ATH在防守过程中通过反制产生的攻击者日志结合威胁情报信息实现对攻击者的多维度线索追踪和黑客画像；通过对其它网络安全产品的多方位安全编排实现高度自动化防御效果；结合研究员进行溯源分析定位攻击者，寻找潜在的APT组织。

典型部署

ATH基于多网段部署感知节点专利技术，在二层环境下无需镜像、无需流量牵引、无需安装agent，实现全内网感知节点部署。如下图例子所示，在运维区旁路trunk接入ATH，便可在各个网络区域、网段快速生成多个高交互的虚拟感知节点。在三层网络环境下，需要配备探针，探针的作用是端口的监听和流量的转发。

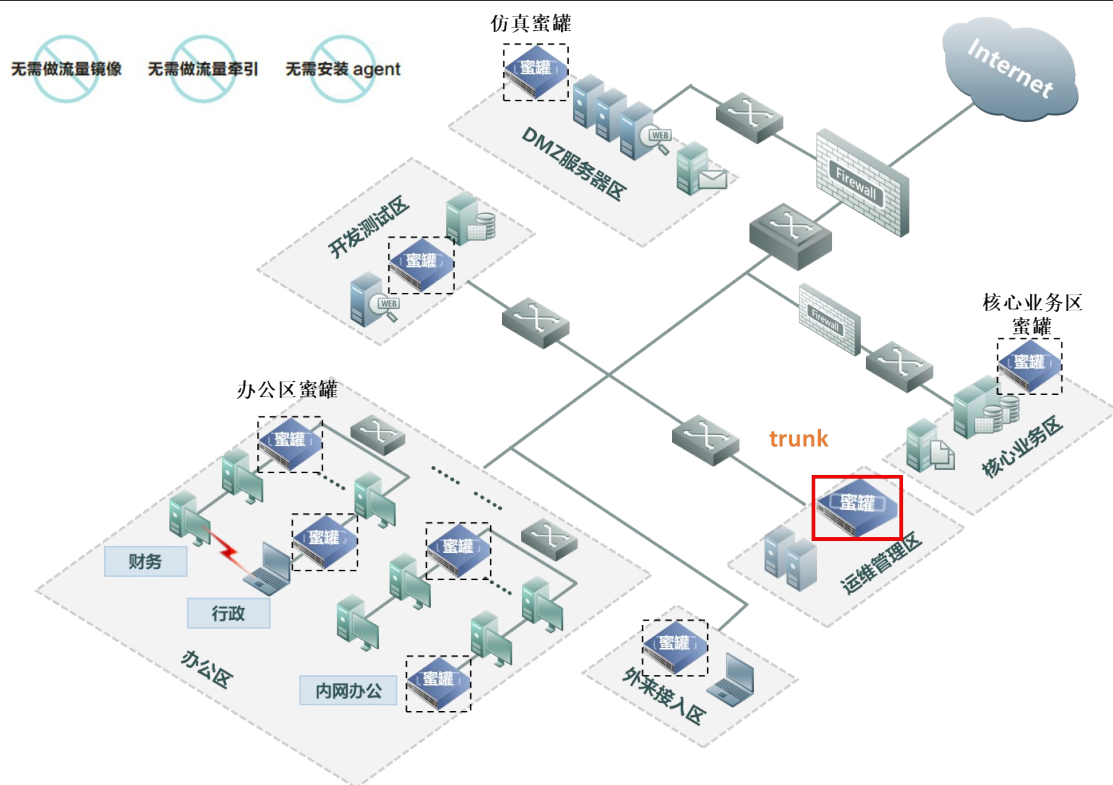


图 3.7 典型部署示意图

支持多种网络场景，能够模拟多个独立办公网络、跨地域网络、DMZ区网络、服务器网络等环境，无需串联业务，独立部署。快速覆盖全场景，兼具实用、弹性、安全和成本优势。

产品优势

技术优势

1. 欺骗防御技术+威胁情报，结合ATT&CK、精准攻击刻画（TTPs）。
2. 强大的溯源能力，精准溯源攻击者，对攻击者进行全面画像。
3. 基于杀伤链的攻击还原，全方位自身安全防护。
4. 漏洞和仿真蜜罐灵活装载，精准识别高级威胁。

体系优势

1. ATH+IPS+WAF+云端中台运营+绿盟研究实验室，联合构建威胁狩猎服务，在HVV等重要时期，对攻击者进行深度溯源，精准定位攻击者。
2. ATH+NTIP/ISOP(绿盟平台类产品)，ATH作为0误报的情报生产源，提供情报生产能力，为客户本地情报平台，提供情报数据。

产品型号规格

表 3.1 虚拟化产品型号规格

	EDR-ATHNX3-VN500	EDR-ATHNX3-VN1000
定位	低端型号	高端型号
产品形态	虚拟化软件	虚拟化软件
节点仿真	支持50个节点仿真	支持100个节点仿真
蜜罐部署数量	50个虚拟蜜罐授权	100个虚拟蜜罐授权

表 3.2 硬件产品型号规格

	EDR-ATHNX3-HD500	EDR-ATHNX3-HD1000	EDR-ATHNX3-HF500
定位	低端型号	中端型号	国产化型号
硬件	2U设备	2U设备	1U设备
节点仿真	支持50个节点仿真	支持100个节点仿真	支持50个节点仿真
蜜罐部署数量	50个虚拟蜜罐授权	100个虚拟蜜罐授权	50个虚拟蜜罐授权
板载网口	2个千兆电口	2个千兆电口	6电4光（注意：此XC型号用不到设备光口，没有适配光模块）
扩展槽	4个扩展槽	4个扩展槽	2个扩展槽
硬盘存储	64G	64G	64G

电源	交流冗余电源	交流冗余电源	交流冗余电源
----	--------	--------	--------

四. 客户价值

化被动为主动，实现高级威胁防御

未知攻焉知防，ATH可有效帮助用户对抗真实攻击者的攻击以及攻防演练，化被动防御为主动防御。依托威胁狩猎系统的感知节点、诱饵、狩猎网络的高交互性，诱导攻击者深度入侵系统，对整个攻击事件进行复现，清晰掌握攻击轨迹和行为细节，结合设备指纹和攻击者画像等技术可以实现攻击溯源，同时清楚掌握内部存在的安全漏洞及风险。对企业网络中的未知威胁和正在发生的攻击行为进行捕获，避免企业业务网络和服务遭受攻击，防范未知安全风险的同时，有效保护企业真实资产安全。

提高攻击成本，拖延攻击者时间

ATH可通过克隆业务的高仿真感知节点，混淆攻击者的攻击目标，让攻击者无法命中真实业务系统，将攻击隔离进ATH的感知节点系统，延缓攻击进程，既能检测攻击者的行为，让攻击者不触碰到真实资产，又能拖延攻击者攻击时间，提供攻击成本，主动暴露攻击者身份、攻击手法、攻击目的等，从而实现攻击隔离。

精准威胁溯源与攻击取证

ATH是一套基于攻击者行为的入侵检测与威胁溯源系统，在发现入侵时监控攻击者，实时掌握攻击态势，全面深度威胁分析。基于KillChain全面记录攻击轨迹和行为，多个维度对攻击者进行画像，实现攻击行为的快速取证溯源。这对于保障客户业务系统的运行连续性和完整性有着极为重要的意义。

企业安全产品联动

ATH可与部署的防火墙、IDS、IPS等基于已知规则的安全防护系统形成安全联动。同时支持通过标准的SYSLOG格式输出告警日志，输出情报到其它安全可视化平台上，帮助客户产生高价值内生威胁情报，联动安全防护设备协助企业快速发现和处置威胁。能够对已知和未知的网络攻击行为进行防御，建立起一套有效保护业务系统安全性的纵深防御体系。

满足监管与合规需求

等级保护2.0等监管条例发布后对安全基本要求有了新的高度，其中对于主动防御、主动预警均有明确要求，条例指出企业应由被动防御体系转变为积极主动防御体系，ATH能够精准诱捕攻击行为，提供入侵活动线索，刻画攻击者画像，助力攻防演练得分。

五. 成功案例

典型成功案例

某大型银行业务网网络安全纵深防御全流量安全监测分析与蜜罐建设项目

项目规模

2022年，某大型银行开始在总行及36家分行范围内部署绿盟全流量安全监测分析及绿盟高级威胁狩猎蜜罐设备，目前部署蜜罐平台数量37台，并配备144台蜜罐硬件探针设备，在2022年通过ATH实现了对攻击行为的主动诱捕与溯源取证。

项目背景

该行历史整体安全防御能力较为单薄，只有部分常规的安全设备，总部与分支没有形成整体化的联防联控机制。从近几年的攻防演练可以发现，针对金融城域网攻击正日益增加，因此对接金融城域网的各城商行/金融机构网络出口/核心区域安全监控能力显得更加重要，使用绿盟科技的全流量解决方案结合威胁狩猎蜜罐系统构建立体安全防护体系，借助基于大数据的流量分析回溯与主动诱捕技术及时发现来自金融城域网侧的各类攻击行为，从而建立全方位纵深防御体系，拉齐全行网络安全监测体系，级联部署加强检测联动的能力，实现日志集中告警、风险统一识别和决策处置。

解决方案

由于该行组织结构复杂、分布地市多、数据相对分散等原因，部署结构采用了分布式部署方式，总行蜜罐平台作为一级管理中心，负责汇接各支行根据诱捕日志产生的安全事件，同时提供统一界面能够对各支行蜜罐仿真服务进行配置管理。36家分行蜜罐平台作为二级管理平台，负责汇接行内部署在不同业务区域的探针捕获的日志，并基于规则生成告警，由分析节点生成安全事件，上报总行一级管理平台。

六. 总结

网络安全的本质是攻防对抗，更本质的是人与人心智与技术的全面较量。尽管有众多的网络安全产品，但是长久以来，网络对抗中，攻防力量从来都是不对等的。在对抗中，攻击方优势远远大于防守方，攻击与防御处于不对等状态，防守一直处于被动防御阶段。并且，随着黑客技术不断发展，网络攻击手段层出不穷，方法日趋多样化，仅仅依靠被动防御技术已经很难抵御攻击了。

直到主动诱饵技术被提出，蜜罐技术兴起，将被动防御变为了主动防御。蜜罐技术是一种网络主动防御技术。蜜罐被定义为：一种安全资源，它的价值就在于被探测、被攻击或被攻陷。通过构建模拟的系统或者服务，达到欺骗攻击者，引诱攻击、增加攻击代价、减少对实际系统或服务安全威胁的目的。它可以是一种服务、一个Web页面、一种数据库或者一个完整的操作系统，甚至可以是一个被监控的文件。总的来说，蜜罐是一个被严格监控的计算机资源，包含了看上去很有攻击价值的虚假诱饵数据和一些已知漏洞，以此吸引入侵者攻击。在蜜罐被入侵的过程中，会实时记录和审计攻击者的攻击流量、行为和数据，用于分析了解攻击者所使用的工具和方法等，便于安全人员后期增强防范措施，攻击溯源、取证等。

绿盟高级威胁狩猎系统（ATH）以此为核心，为一款以欺骗防御、威胁情报、AI分析、主动识别技术为核心，结合云端运营、威胁狩猎对客户网络中潜在威胁进行检测和发现的安全攻防产品；具备结合威胁情报实现对黑客的诱捕、溯源、反制和画像的能力。能够辅助用户溯源背后的攻击者，保护客户资产安全。